

Ford Retention AI

Arquitetura da API REST para aumentar o **Service Share / VIN Share** no pós-venda da Ford na América do Sul.

STACK	Java 21 · Spring Boot 3.5 · Spring Security + JWT · JPA · Oracle 19c
CONSUMIDORES	App mobile (React Native) · Dashboard · Modelo de ML (Random Forest)
REPOSITÓRIO	github.com/3ESPG/Sprint3-SOA-Java

CONTEÚDO

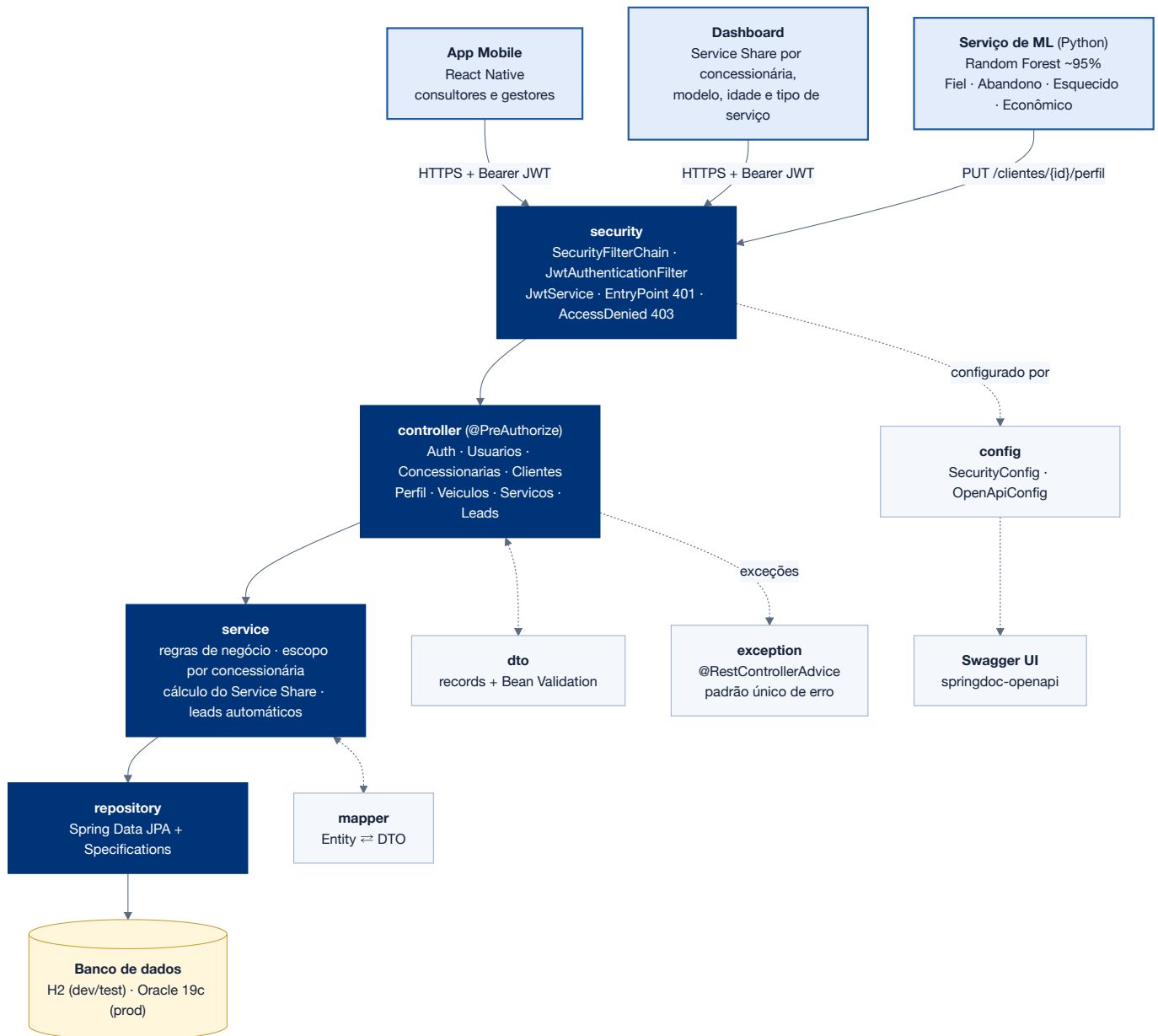
- | | |
|--------------------------------|--|
| 1. Visão de componentes | 5. Integração com o ML e geração automática de leads |
| 2. Camadas e responsabilidades | 6. Modelo de domínio |
| 3. Login e emissão do JWT | 7. Matriz de autorização |
| 4. Requisição protegida | |

INTEGRANTES

Felipe Braunstein e Silva	RM554483
Felipe do Nascimento Fernandes	RM554598
Henrique Ignacio Bartalo	RM555274
Gustavo Henrique Martins	RM556956

Visão de componentes

Quem consome a API, as camadas internas e onde ficam os dados.



Todas as chamadas passam pelo `SecurityFilterChain`. O `JwtAuthenticationFilter` valida o token antes de qualquer controller. Os erros de todas as camadas saem no mesmo formato JSON pelo `@RestControllerAdvice`. O banco é H2 em dev/teste e Oracle 19c em produção.

Pacote	Responsabilidade
<code>controller</code>	Só HTTP: valida os DTOs (<code>@Valid</code>), aplica <code>@PreAuthorize</code> e devolve o status certo (201 + <code>Location</code> , 204...). Não tem regra de negócio.
<code>service</code>	Regras de negócio e transações, escopo de dados pelo <code>concessionariaId</code> do token, cálculo do Service Share e geração automática de leads.
<code>repository</code>	Spring Data JPA. Os filtros dinâmicos das listagens usam <code>Specification</code> .
<code>model</code>	Entidades JPA e enums do domínio.
<code>dto</code>	Contratos de entrada e saída (records). As entidades nunca saem da API.
<code>mapper</code>	Conversão entre entidade e DTO, sem dependências externas.
<code>security</code>	Geração e validação do JWT, filtro <code>OncePerRequestFilter</code> , <code>UserDetailsService</code> e handlers de 401/403 no formato de erro da API.
<code>exception</code>	Exceções de domínio e o <code>GlobalExceptionHandler</code> com o formato único de erro.
<code>config</code>	<code>SecurityFilterChain</code> , <code>BCrypt</code> , OpenAPI com esquema Bearer, <code>Clock</code> injetável e limite do score de lead.

Onde entra cada consumidor

App mobile

Consultores trabalham a fila de leads e avançam o status (`PATCH /leads/{id}/status`). Gestores veem clientes, veículos e leads da própria concessionária.

Dashboard

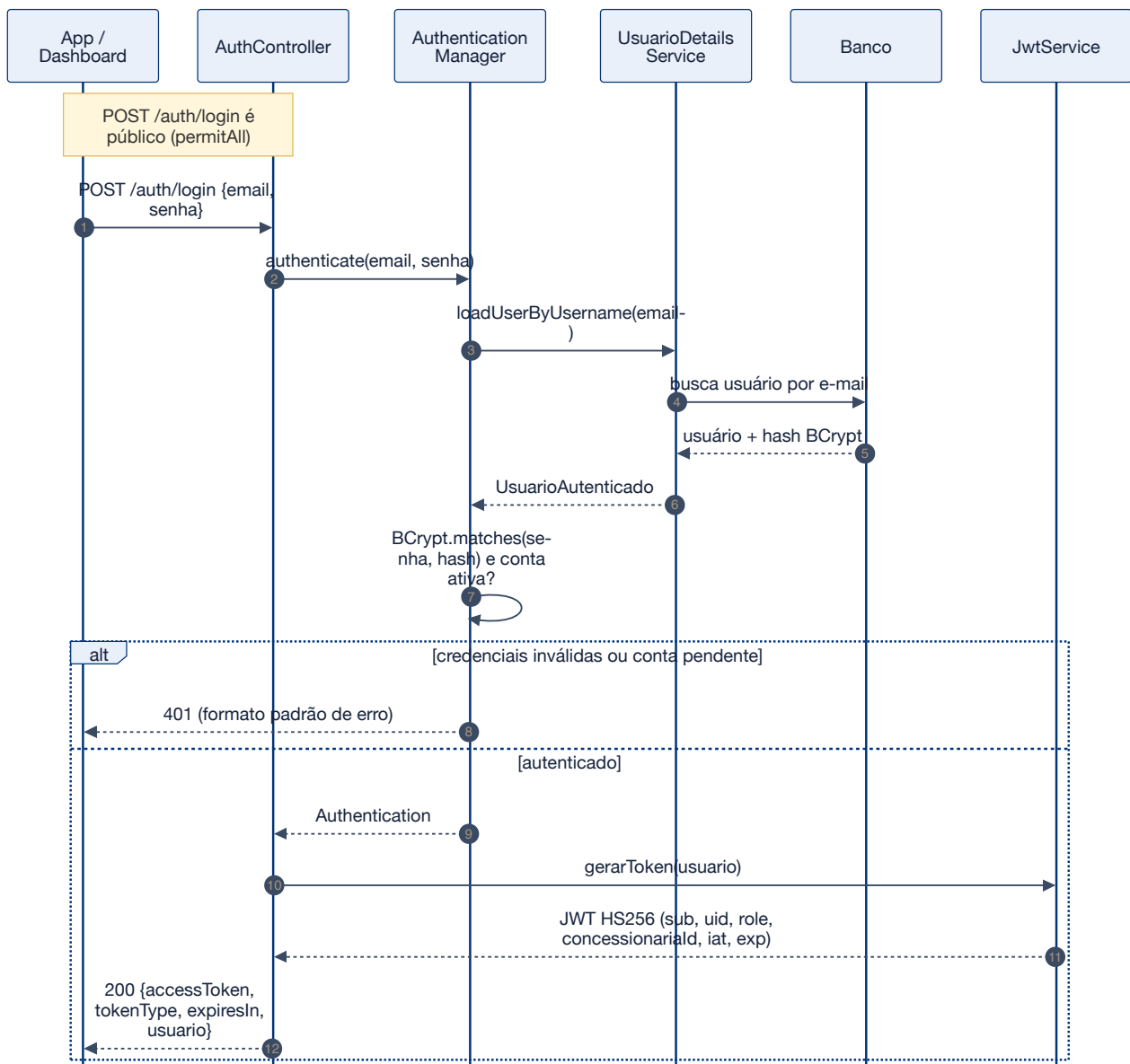
Consome `GET /concessionarias/{id}/service-share` , com recortes por idade do veículo, modelo e tipo de serviço, e as listagens paginadas com filtros.

Serviço de ML

O notebook Python calcula perfil e score e chama `PUT /clientes/{id}/perfil` com um usuário técnico ADMIN. A API grava o perfil e gera leads.

Login e emissão do JWT

Credenciais validadas com BCrypt; token HS256 assinado com o segredo de JWT_SECRET.



Claims do token

sub (e-mail), uid, nome, role, concessionariaId (ausente para ADMIN), iss, iat e exp.

Expiração

Configurável por `JWT_EXPIRATION` (padrão 1h). O segredo vem sempre de variável de ambiente, com no mínimo 256 bits.

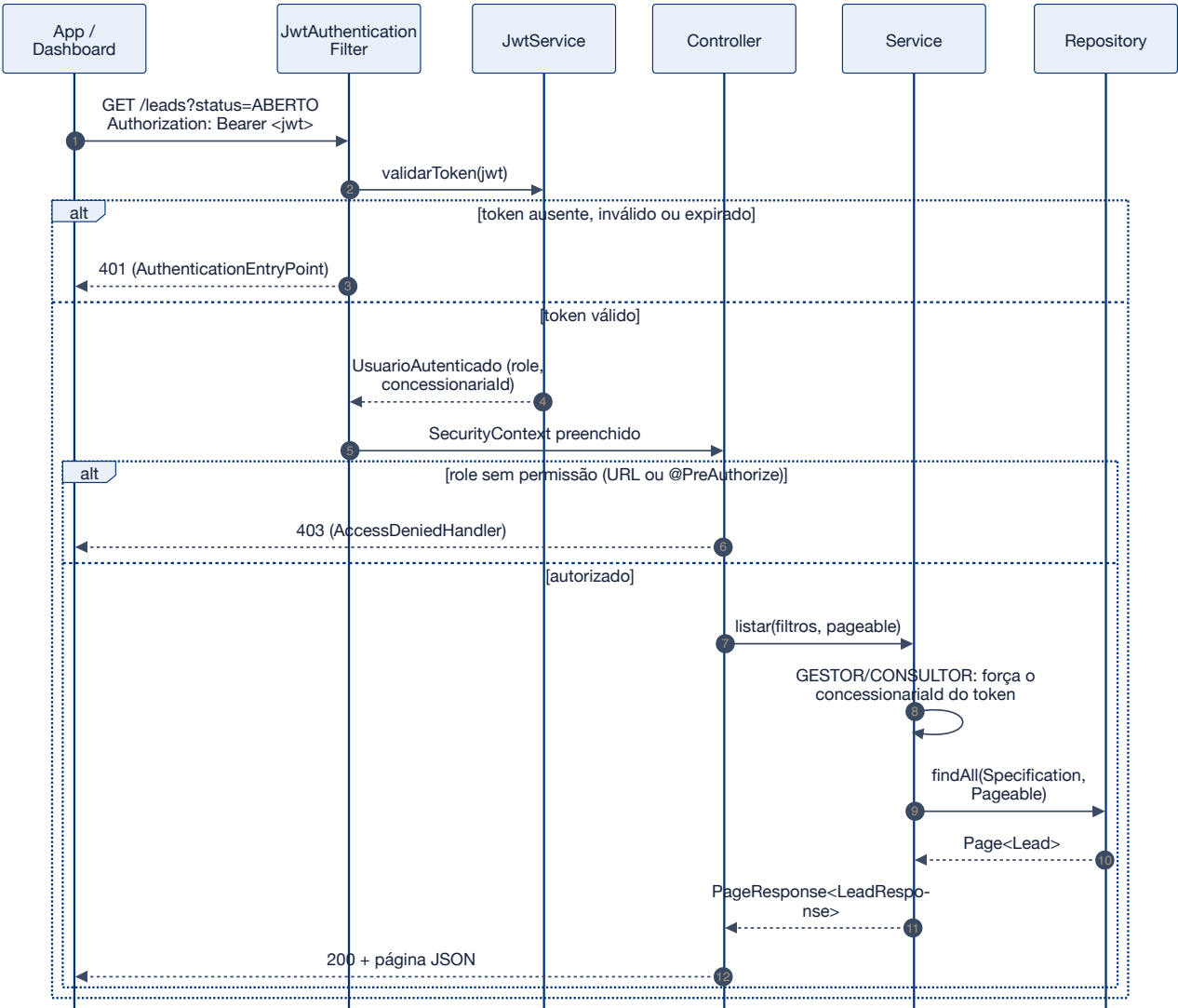
Endpoints públicos

`/auth/login`, `/auth/register`, Swagger e `/actuator/health`.
Todo o resto exige Bearer.

4

Requisição protegida

Filtro JWT → autorização por perfil → escopo pela concessionária do token.



401 Unauthorized

Token ausente, malformado, com assinatura inválida ou expirado. Resposta no formato padrão, com o header `WWW-Authenticate: Bearer`.

403 Forbidden

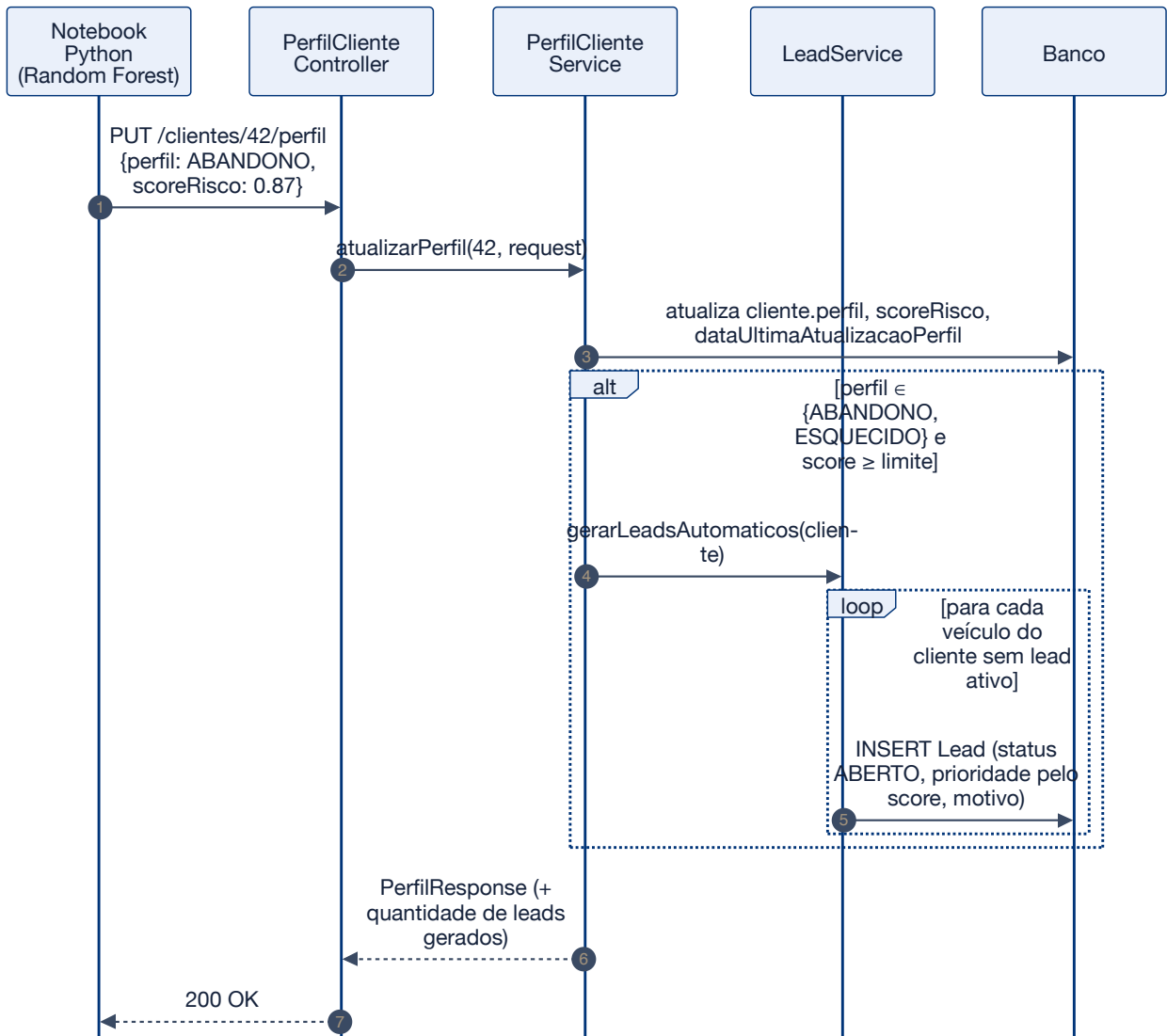
O perfil não pode executar a operação (regra de URL ou `@PreAuthorize`), ou o payload aponta para outra concessionária.

404 Not Found

O recurso não existe ou pertence a outra concessionária. Assim a API não revela dados fora do escopo do token.

Integração com o ML e leads automáticos

O perfil calculado pelo Random Forest vira ação para a concessionária.



Regra de geração

Perfil **ABANDONO** ou **ESQUECIDO** com score $\geq 0,70$ gera um lead para cada veículo do cliente sem lead ativo.

Prioridade

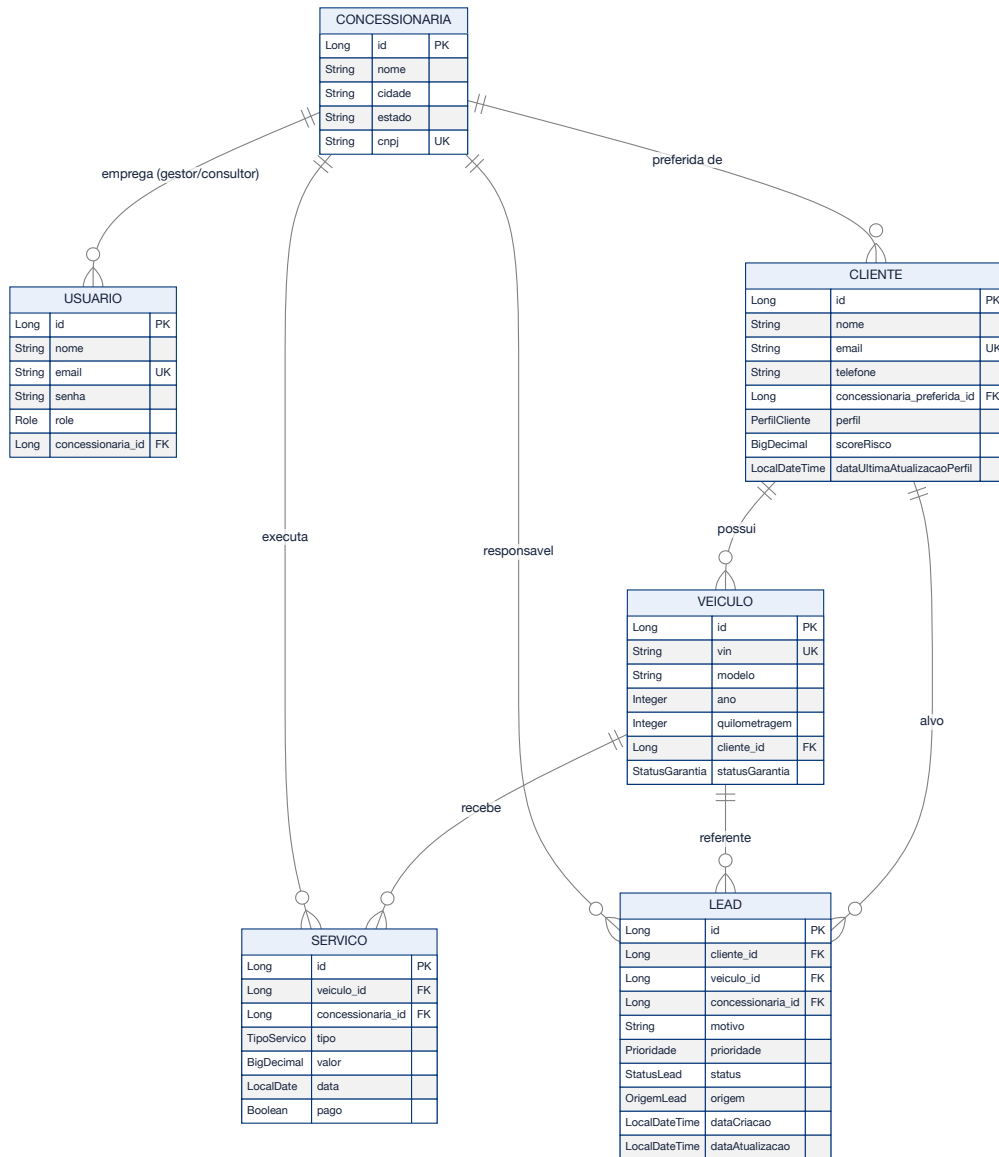
Score $\geq 0,90 \rightarrow$ **ALTA**
 $\geq 0,80 \rightarrow$ **MÉDIA**
abaixo $\rightarrow$ **BAIXA**

Fechamento do ciclo

Quando um serviço **pago** é registrado para o veículo, os leads ativos dele passam a **CONVERTIDO**.

Service Share

$$\frac{\text{clientes da base com } \geq 1 \text{ serviço pago na rede Ford nos últimos 12 meses}}{\text{clientes da base da concessionária que possuem veículo}} \times 100$$



Enum

Valores

Role

ADMIN · GESTOR_CONCESSIONARIA · CONSULTOR

PerfilCliente

FIEL · ABANDONO · ESQUECIDO · ECONOMICO (definido pelo modelo de ML)

StatusGarantia

ATIVA · EXPIRADA · ESTENDIDA

TipoServico

REVISAO · REPARO · PECAS · RECALL · GARANTIA

StatusLead

ABERTO → CONTATADO → AGENDADO → CONVERTIDO · PERDIDO

Prioridade / OrigemLead

ALTA · MEDIA · BAIXA / MODELO_ML · MANUAL

Recurso / ação	ADMIN	GESTOR_CONCESSIONARIA	CONSULTOR
POST /auth/login, /auth/register	público	público	público
GET /concessionarias, /{id}	todas	só a própria	só a própria
POST/PUT/PATCH/DELETE /concessionarias	sim	403	403
GET /concessionarias/{id}/service-share	todas	só a própria	403
/clientes, /veiculos, /servicos: leitura	todos	só a própria	só a própria
/clientes, /veiculos, /servicos: escrita	sim	só a própria	403
PUT /clientes/{id}/perfil (ML)	sim	403	403
GET /clientes/{id}/perfil	sim	só a própria	só a própria
GET /leads, /leads/{id}	todos	só a própria	só a própria
POST /leads, PUT /leads/{id}	sim	só a própria	403
PATCH /leads/{id}/status	sim	só a própria	só a própria
DELETE /leads/{id}	sim	403	403
GET /usuarios	todos	só a própria	403
GET /usuarios/{id}	todos	só a própria	só a si mesmo
POST /usuarios (qualquer perfil)	sim	403	403
PATCH /usuarios/{id}/ativacao	sim	consultores da própria	403

Escopo pelo token

O concessionariaId do JWT restringe gestores e consultores. Um recurso de outra concessionária retorna **404**, para não revelar que ele existe. Um payload que aponta para outra concessionária retorna **403**.

Auto-cadastro seguro

POST /auth/register cria apenas **CONSULTOR inativo**. O acesso só é liberado após aprovação de um ADMIN ou do gestor da concessionária.